



BTL môn học An toàn bảo mật thông tin.

Giảng viên: Nhật Dương.

Thành viên nhóm: Lê Đình Chính – 0169867.

Nguyễn Xuân Hoàng – 0034267.

Đỗ Đại Nghĩa - 1500167.

Đề tài:

DNS Spoofing / DNS Cache Poisoning

Mục tiêu tài liệu:

Mục tiêu với tài liệu này: trình bày cặn kẽ và dễ hiểu về **DNS Spoofing** (từ khái niệm, các hình thức tấn công, tới cách phát hiện và phòng ngừa), đồng thời có một phần demo trong môi trường lab để minh họa hậu quả thực tế, từ đó nhận thức được mức độ nguy hiểm của DNS Spoofing.

Mục lục

I. Tổng quan về DNS Spoofing

1. Internet và rủi ro bảo mật
2. Ví dụ thực tế về tấn công DNS Spoofing (vụ Dan Kaminsky 2008)
3. Vấn đề đặt ra: DNS Spoofing là gì và làm thế nào để bảo vệ?

II. DNS Spoofing là gì?

1. Khái niệm
2. Minh họa hoạt động của DNS
3. Cách thức giả mạo bản ghi DNS

III. DNS Spoofing nguy hiểm như thế nào?

1. Đánh cắp thông tin cá nhân
2. Cài mã độc (virus, ransomware)
3. Tạo trang web giả mạo để lừa đảo
4. Kiểm soát website doanh nghiệp
5. Làm gián đoạn dịch vụ doanh nghiệp
6. Mất uy tín thương hiệu

IV. Cách thức hoạt động của một cuộc tấn công DNS Cache Poisoning

1. Gửi yêu cầu truy cập
2. Tra cứu DNS
3. Kẻ tấn công xen vào
4. Phản hồi giả mạo
5. Chuyển hướng người dùng

V. Các loại hình tấn công DNS Spoofing phổ biến

1. Tấn công bộ nhớ đệm (DNS Cache Poisoning)
2. Phần mềm độc hại (Malware-based)
3. Tấn công Man-in-the-Middle (MITM)

VI. Các trường hợp sử dụng DNS Spoofing

1. Chuyển hướng người dùng đến trang web giả mạo
2. Tấn công Man-in-the-Middle (MitM)
3. Độc chiếm bộ nhớ cache DNS (DNS Cache Poisoning)
4. Tấn công từ chối dịch vụ khuếch đại DNS (DNS Amplification Attack)

VII. Dấu hiệu nhận biết máy tính bị DNS Spoofing

1. Trang web hiển thị bất thường, có lỗi
2. Bị chuyển hướng sang trang lạ, nhiều quảng cáo
3. Yêu cầu đăng nhập liên tục
4. Chứng chỉ HTTPS bất thường
5. Tốc độ tải trang chậm
6. Cảnh báo bảo mật từ trình duyệt

VIII. Cách phòng chống DNS Spoofing hiệu quả

1. Sử dụng DNS an toàn (Cloudflare, Google Public DNS)

2. Cài đặt phần mềm bảo mật uy tín
3. Hạn chế dùng Wi-Fi công cộng
4. Luôn kiểm tra tên miền trước khi nhập thông tin
5. Cập nhật hệ điều hành và phần mềm
6. Sử dụng DNSSEC để xác thực bản ghi DNS
7. Dùng HTTPS, SSL/TLS
8. Triển khai VPN, tường lửa
9. Cập nhật phần mềm và firmware thiết bị mạng
10. Giám sát hệ thống DNS thường xuyên

Biện pháp nâng cao:

11. Random hóa Transaction ID và Source Port
12. DNS over HTTPS (DoH) vs DNS over TLS (DoT) — so sánh ngắn
13. DNS Monitoring & Threat Intelligence

IX. Các hình thức tấn công DNS Spoofing phổ biến ở Việt Nam

1. Malware thay đổi DNS (client-side DNS hijack)
2. Router / modem compromise (DNS trên router bị đổi)
3. Wi-Fi công cộng + MITM (Rogue AP / ARP spoofing)
4. Phishing kết hợp DNS hijack (nhắm ngân hàng)
5. DNS Cache Poisoning nhắm resolver ISP/điểm trung gian
6. Rogue Public Resolver / DHCP cung cấp DNS độc hại
7. DNS Rebinding (nhắm IoT / dịch vụ nội bộ)

X. Demo hình thức tấn công DNS Spoofing.

1. Chuẩn bị các thiết bị
2. Thiết lập ETTERCAP trên KALI LINUX

2.1. Host web giả mạo trên python

2.2. Thiết lập Ettercap (etter.dns)

2.3. Tổ chức tấn công

3. Kiểm tra kết quả

XI. Kết luận

1. DNS Spoofing là mối đe dọa thực sự

2. Ý nghĩa của việc hiểu rõ bản chất và phòng chống

3. Lời khuyên về nâng cao cảnh giác

I. Tổng quan về DNS Spoofing

Internet mang lại nhiều tiện ích trong công việc, học tập và giải trí, nhưng cũng tiềm ẩn không ít rủi ro bảo mật. Một trong những mối đe dọa nguy hiểm nhất là DNS Spoofing.



Ví dụ thực tế về tấn công DNS Spoofing

DNS Spoofing không phải là một mối đe dọa trên lý thuyết. Trong thực tế, đã có nhiều cuộc tấn công lớn gây thiệt hại đáng kể.

Một vụ việc nổi tiếng xảy ra vào năm 2008, khi một hacker có tên Dan Kaminsky đã phát hiện một lỗ hổng nghiêm trọng trong giao thức DNS. Lỗ hổng này cho phép kẻ tấn công dễ dàng thực hiện các cuộc tấn công DNS Cache Poisoning trên diện rộng. Vụ việc này đã gây chấn động cộng đồng an ninh mạng và thúc đẩy việc phát triển các giao thức bảo mật mới như DNSSEC.

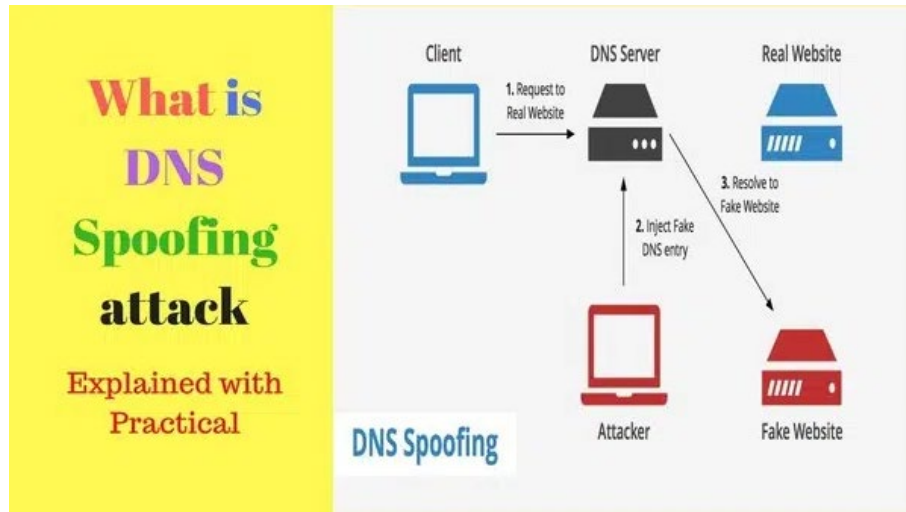


Vậy DNS Spoofing là gì và làm thế nào để bảo vệ bản thân khỏi hình thức tấn công này ?

II. DNS spoofing là gì ?

DNS Spoofing, hay còn gọi là DNS Cache Poisoning, là một hình thức hack bảo mật máy tính trong đó dữ liệu hệ thống tên miền bị hỏng được đưa vào bộ đệm của trình phân giải DNS, khiến máy chủ tên trả về bản ghi kết quả không chính xác. Điều này dẫn đến lưu lượng truy cập được chuyển hướng đến máy tính của kẻ tấn công (hoặc bất kỳ máy tính nào khác).

Khi đó, người dùng truy cập đến địa chỉ mong muốn nhưng sẽ được gửi đến một địa chỉ IP giả mạo. Địa chỉ IP giả mạo này đã được kẻ tấn công tạo ra trước đó với mục đích ăn cắp thông tin tài khoản ngân hàng của người dùng.



Hãy hình dung thế này: DNS (Domain Name System) giống như cuốn danh bạ điện thoại của Internet. Khi bạn gõ “Interdata.vn” vào trình duyệt, trình duyệt sẽ tra cứu trong “danh bạ” này để tìm địa chỉ IP tương ứng. Tuy nhiên, kẻ tấn công đã trà trộn vào và thay đổi số điện thoại trong danh bạ, khiến bạn bị chuyển hướng sang một địa chỉ khác.

Đây chính là lúc cuộc tấn công **DNS Spoofing** xảy ra. Kẻ xấu sẽ chèn một bản ghi DNS giả mạo vào hệ thống, lừa trình duyệt và người dùng truy cập vào trang web giả mạo mà chúng đã tạo ra, mục đích cuối cùng là để đánh cắp thông tin cá nhân hoặc lây lan phần mềm độc hại.

III. DNS Spoofing nguy hiểm như thế nào?

DNS Spoofing không chỉ là một trò đùa, mà là một mối đe dọa nghiêm trọng với người dùng cá nhân và cả doanh nghiệp. Hậu quả của một cuộc tấn công DNS Spoofing có thể rất nặng nề, bao gồm:

1. Đánh cắp thông tin cá nhân

Kẻ tấn công sẽ tạo ra một trang web giả mạo có giao diện y hệt trang web thật, khi bạn truy cập nhầm vào trang này và nhập thông tin đăng nhập, mật

khẩu, hoặc thậm chí là thông tin thẻ tín dụng, toàn bộ dữ liệu sẽ bị gửi về cho kẻ xấu.



2. Cài mã độc (virus, ransomware)

Một số cuộc tấn công DNS Spoofing được thiết kế để lừa người dùng tải xuống và cài đặt các tệp tin độc hại. Những tệp này có thể chứa virus, Trojan, hoặc ransomware, làm tê liệt hệ thống và đòi tiền chuộc.



3. Tạo trang web giả mạo để lừa đảo

Đây là một trong những mục đích phổ biến nhất của **DNS Spoofing**, các trang web giả mạo này có thể được dùng để lừa đảo tài chính, chiếm đoạt tài khoản mạng xã hội, hoặc thực hiện các hành vi phi pháp khác.



4. Kiểm soát website của doanh nghiệp

Nếu một doanh nghiệp bị tấn công **DNS Spoofing**, tất cả người dùng truy cập website của họ có thể bị chuyển hướng đến một trang lừa đảo. Điều này không chỉ gây thiệt hại về tài chính mà còn ảnh hưởng nặng nề đến uy tín thương hiệu.



5. Làm gián đoạn dịch vụ doanh nghiệp

Khi hệ thống DNS bị can thiệp, hoạt động của website và các dịch vụ trực tuyến có thể bị gián đoạn, gây ảnh hưởng đến hiệu quả kinh doanh và trải nghiệm của khách hàng.



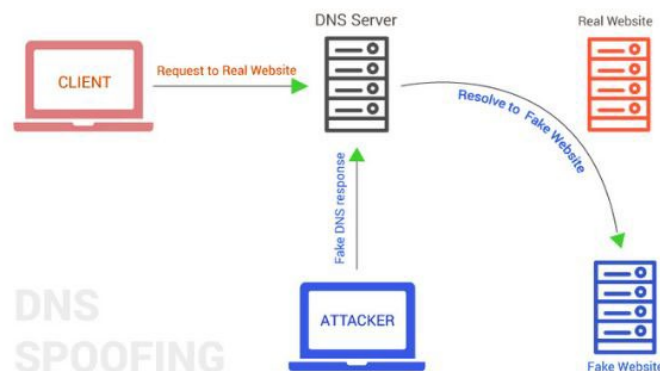
6. Mất uy tín thương hiệu

Khi khách hàng bị lừa đảo trên website giả mạo, họ sẽ mất niềm tin vào thương hiệu của bạn, dẫn đến những tổn thất lâu dài về uy tín và doanh thu.



IV. Cách thức hoạt động của một cuộc tấn công DNS cache poisoning

Để hiểu rõ hơn về cách phòng chống, bạn cần biết **DNS Spoofing** hoạt động như thế nào.



Một cuộc tấn công điển hình thường diễn ra theo các bước sau:

- **Gửi yêu cầu truy cập:** Bạn gõ tên miền của một trang web vào trình duyệt, ví dụ: “<https://www.google.com/search?q=google.com>”.
- **Tra cứu DNS:** Trình duyệt sẽ gửi yêu cầu đến máy chủ DNS để tìm địa chỉ IP của trang web.
- **Kẻ tấn công xen vào:** Kẻ tấn công sẽ chèn một bản ghi DNS giả mạo vào bộ nhớ cache của máy chủ DNS, trước khi máy chủ này nhận được phản hồi từ máy chủ chính thức.
- **Phản hồi giả mạo:** Máy chủ DNS gửi địa chỉ IP giả mạo này về trình duyệt của bạn.
- **Chuyển hướng người dùng:** Trình duyệt sẽ truy cập vào địa chỉ IP giả mạo, và bạn bị chuyển hướng đến trang web lừa đảo.

Kỹ thuật tấn công này được gọi là DNS Cache Poisoning, bởi vì nó “đầu độc” bộ nhớ cache của máy chủ DNS bằng thông tin sai lệch.

V. Các loại hình tấn công DNS Spoofing phổ biến

DNS Spoofing có nhiều hình thức khác nhau, nhưng phổ biến nhất là 3 loại sau:

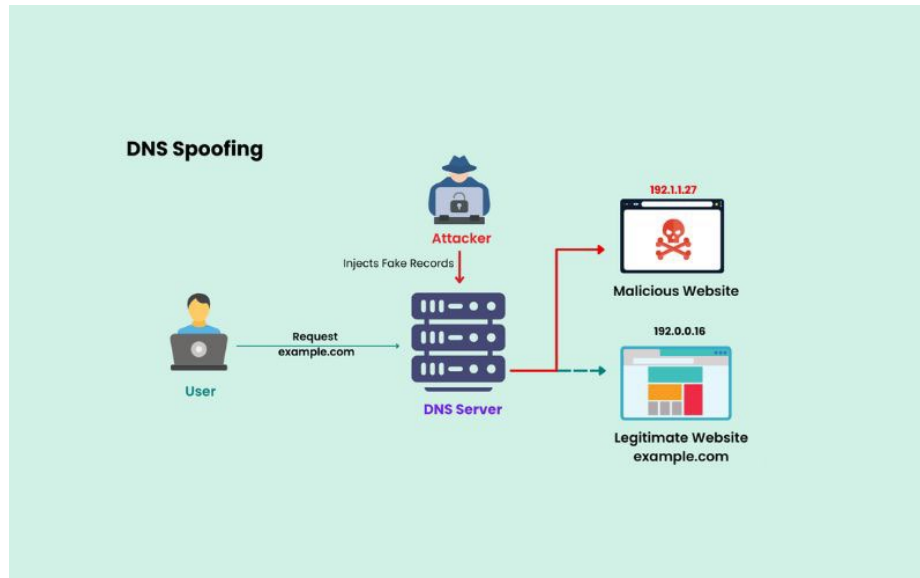
- **Tấn công bộ nhớ đệm (DNS Cache Poisoning):** Đây là hình thức phổ biến nhất. Kẻ tấn công tiêm dữ liệu giả mạo vào bộ nhớ cache của máy chủ DNS, khiến các yêu cầu DNS tiếp theo đều trả về địa chỉ IP của trang web lừa đảo.
- **Phần mềm độc hại (Malware-based):** Kẻ tấn công lừa bạn cài đặt một phần mềm độc hại. Phần mềm này sẽ thay đổi cài đặt DNS trên máy tính của bạn, khiến mọi yêu cầu truy cập website đều bị chuyển hướng.
- **Tấn công Man-in-the-Middle (MITM):** Kẻ tấn công đứng giữa kết nối của bạn và máy chủ DNS. Khi bạn gửi yêu cầu, chúng sẽ chặn lại và gửi phản hồi giả mạo về máy tính của bạn.

VI. Các trường hợp sử dụng DNS Spoofing

Các trường hợp sử dụng DNS Spoofing gồm có:

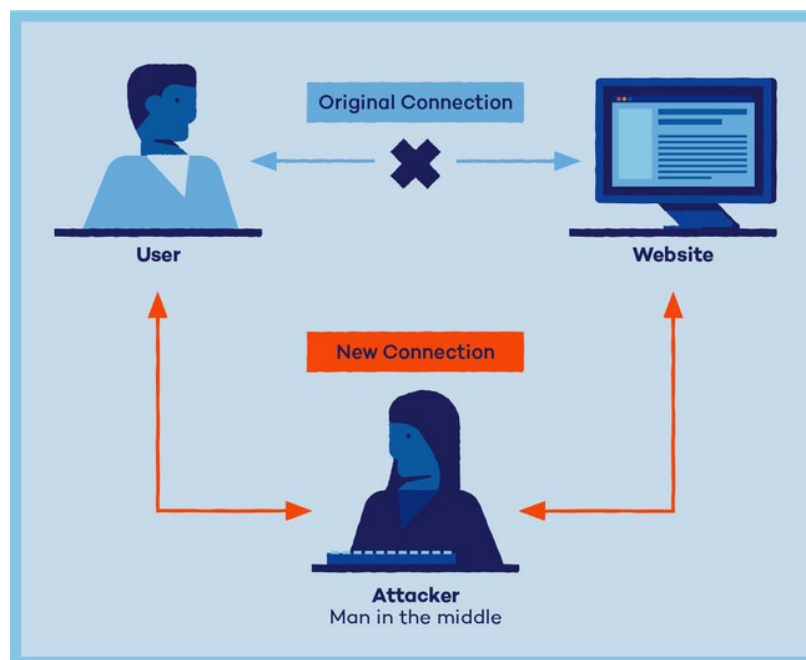
1. Chuyển hướng người dùng đến trang web giả mạo

Hacker thay đổi các bản ghi DNS để khi người dùng truy cập tên miền hợp pháp, họ sẽ bị chuyển sang địa chỉ IP của máy chủ giả mạo do hacker kiểm soát. Từ đó hacker có thể thu thập thông tin cá nhân, tài khoản ngân hàng, mật khẩu hoặc cài mã độc vào máy người dùng.



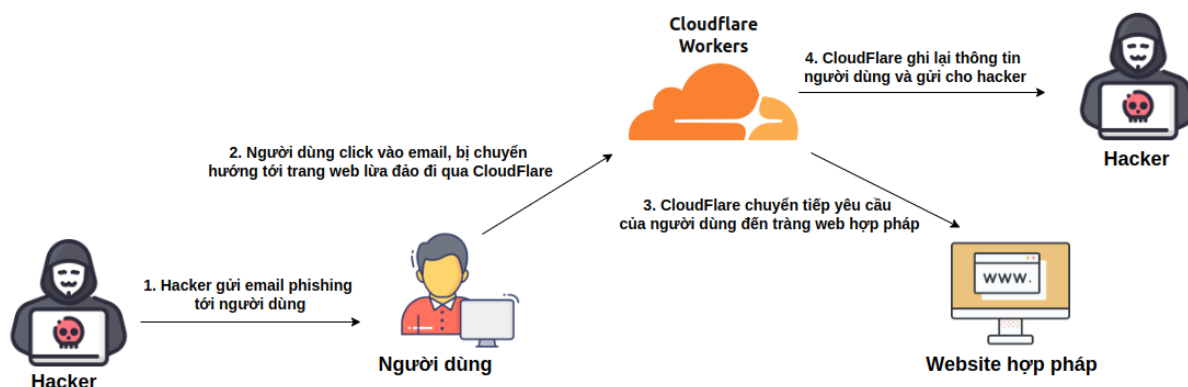
2. Tấn công Man-in-the-Middle (MitM)

Qua DNS Spoofing, hacker có thể kiểm soát lưu lượng truy cập mạng và thực hiện tấn công MitM, thu thập, chỉnh sửa dữ liệu truyền qua, ví dụ trong mạng nội bộ (LAN), kết hợp với ARP Spoofing để tấn công DNS nội bộ (Intranet DNS Spoofing) nhằm chiếm quyền điều khiển DNS server hoặc router.



3. Độc chiếm bộ nhớ cache DNS (DNS Cache Poisoning)

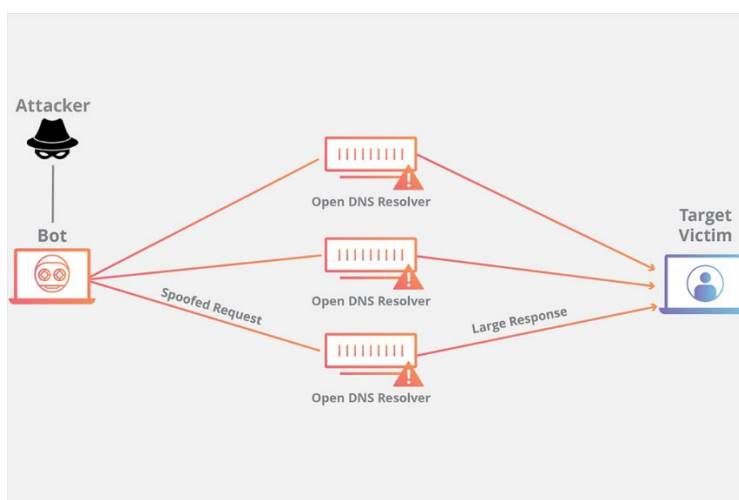
Hacker tiêm các bản ghi DNS giả mạo vào bộ nhớ cache của các DNS resolver. Khi người dùng trên mạng yêu cầu truy cập tên miền đó, sẽ nhận kết quả giả mạo dẫn đến trang độc hại mà hacker thiết lập.



4. Tấn công từ chối dịch vụ khuếch đại DNS (DNS Amplification Attack)

Dù không phải DNS Spoofing trực tiếp, nhưng hacker lợi dụng kỹ thuật giả mạo IP nguồn trong truy vấn DNS để tạo lưu lượng tấn công lớn, làm nghẽn mạng của nạn nhân.

DNS Spoofing được sử dụng chủ yếu để chuyển hướng người dùng đến các trang giả mạo nhằm đánh cắp thông tin hoặc triển khai mã độc, đồng thời cũng có thể kết hợp với các kỹ thuật khác để tấn công mạng sâu hơn hoặc gây gián đoạn dịch vụ.

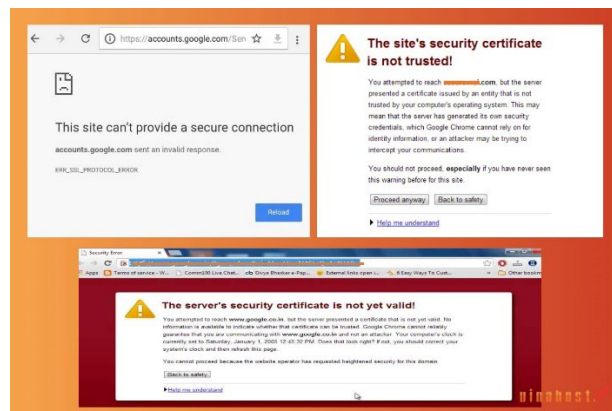


Tuy nhiên, cần nhấn mạnh rằng hầu hết các trường hợp sử dụng DNS Spoofing đều là để thực hiện hành vi phi pháp, và người dùng cần phải cảnh giác.

VII. Dấu hiệu nhận biết máy tính bị DNS Spoofing

Bạn có thể trở thành nạn nhân của **DNS Spoofing** bất cứ lúc nào mà không hề hay biết. Vì vậy, việc nhận biết các dấu hiệu sớm là vô cùng quan trọng.

- **Trang web hiển thị bất thường, có lỗi:** Trang web bạn truy cập trông khác lạ, có lỗi chính tả hoặc không hiển thị đầy đủ các thành phần.



- **Bị chuyển hướng sang các trang lạ, nhiều quảng cáo:** Thay vì truy cập vào trang web mong muốn, bạn lại bị chuyển hướng đến một trang web lạ, đầy rẫy quảng cáo pop-up.



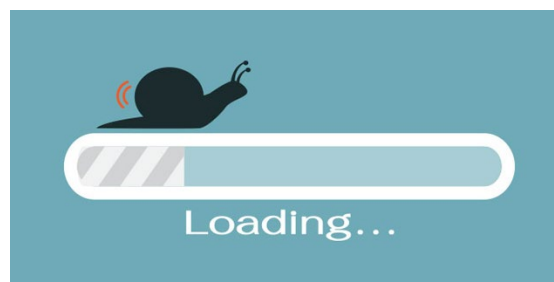
- **Yêu cầu đăng nhập lại tài khoản liên tục:** Khi truy cập vào các trang quen thuộc (ví dụ: Gmail, Facebook), bạn liên tục bị yêu cầu đăng nhập lại, ngay cả khi bạn vừa đăng nhập xong.



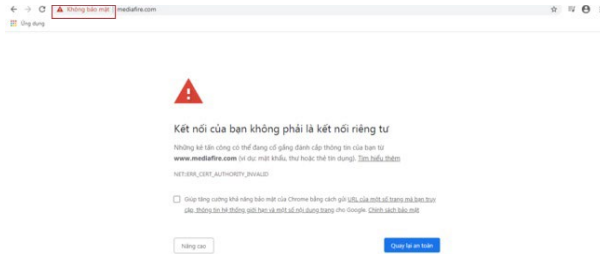
- **Chứng chỉ HTTPS bất thường:** Các trang web an toàn thường có biểu tượng ổ khóa và chứng chỉ HTTPS trên thanh địa chỉ. Nếu bạn thấy biểu tượng này bị thiếu hoặc có cảnh báo bảo mật, hãy cẩn thận.



- **Tốc độ tải trang chậm:** Đôi khi, việc chuyển hướng đến máy chủ giả mạo có thể làm giảm tốc độ tải trang một cách đáng kể.



- **Cảnh báo bảo mật từ trình duyệt:** Các trình duyệt hiện đại như Chrome, Firefox có tính năng cảnh báo khi bạn truy cập vào các trang web có nguy cơ bảo mật cao. Hãy chú ý đến những cảnh báo này.



VIII. Cách phòng chống DNS Spoofing hiệu quả nhất

Bảo vệ bản thân khỏi **DNS Spoofing** không hề phức tạp. Chỉ với một vài thao tác đơn giản, bạn có thể giảm thiểu rủi ro đáng kể.

1. Sử dụng DNS an toàn

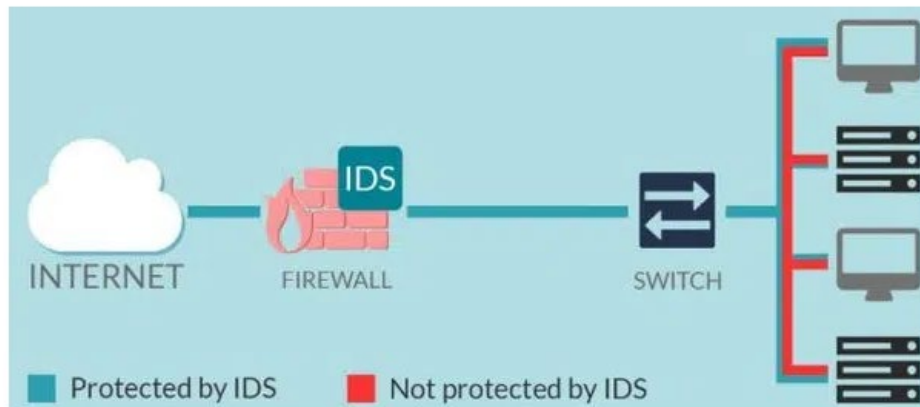
Thay vì sử dụng DNS mặc định của nhà mạng, hãy chuyển sang các máy chủ DNS công cộng, uy tín như Cloudflare (1.1.1.1) hoặc Google Public DNS (8.8.8.8) thường có hệ thống bảo mật tốt, hỗ trợ DoH/DoT và cập nhật nhanh, nhưng không phải tuyệt đối an toàn; lựa chọn resolver cần cân nhắc chính sách riêng tư và hỗ trợ DoH/DoT.



2. Cài đặt phần mềm bảo mật uy tín

Một phần mềm diệt virus hoặc phần mềm bảo mật mạng có tính năng chống tấn công **DNS Spoofing** là lá chắn đầu tiên của bạn. Các phần mềm này có

thể phát hiện và ngăn chặn các mã độc cố gắng thay đổi cài đặt DNS trên máy tính.



Sử dụng hệ thống phát hiện xâm nhập – IDS để phòng chống DNS Spoofing

3. Hạn chế dùng Wi-Fi công cộng

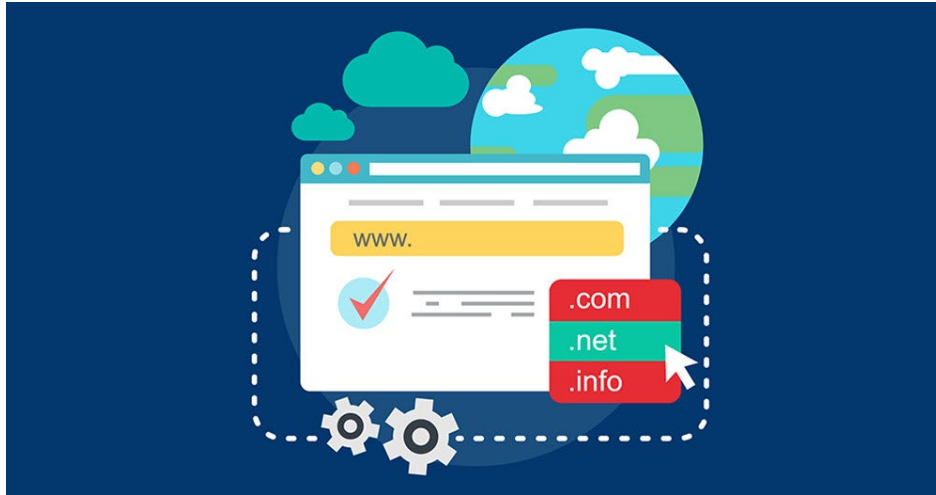
Wi-Fi công cộng thường không có hệ thống bảo mật tốt, tạo điều kiện thuận lợi cho kẻ tấn công thực hiện các cuộc tấn công **DNS Spoofing** kiểu MITM. Hạn chế thực hiện các giao dịch quan trọng (ngân hàng, thanh toán) khi kết nối Wi-Fi công cộng.



4. Luôn kiểm tra tên miền

Trước khi nhập bất kỳ thông tin cá nhân nào, hãy kiểm tra kỹ tên miền trên thanh địa chỉ của trình duyệt. Hãy chắc chắn rằng tên miền đó chính xác, không có lỗi chính tả (ví dụ:

“https://www.google.com/search?q=google.com” thay vì
“https://www.google.com/search?q=google.com”).



5. Cập nhật hệ điều hành và phần mềm

Các bản vá lỗi bảo mật định kỳ của hệ điều hành và phần mềm giúp khắc phục các lỗ hổng có thể bị kẻ tấn công khai thác. Luôn đảm bảo hệ thống của bạn được cập nhật mới nhất.



6. Sử dụng DNSSEC để xác thực bản ghi DNS

DNSSEC xác thực dữ liệu DNS (RRSIG/DS) để đảm bảo bản ghi không bị thay đổi; nó không mã hóa truy vấn DNS và cần triển khai cả trên zone và resolver để có hiệu lực. DNSSEC giúp ngăn chặn các cuộc tấn công **DNS Spoofing** bằng cách đảm bảo rằng bản ghi DNS bạn nhận được là chính xác và không bị giả mạo.



DNSSEC là một giải pháp mới để phòng chống DNS Spoofing

7. Dùng HTTPS, SSL/TLS

HTTPS/SSL giúp bảo vệ dữ liệu và đảm bảo tính xác thực của kết nối — nếu trình duyệt báo chứng chỉ hợp lệ, điều đó giúp phát hiện trang giả mạo.

Tuy nhiên, HTTPS không hoàn toàn vô hiệu hóa rủi ro chuyển hướng DNS; trình giả mạo có thể vẫn chuyển hướng người dùng đến một site khác (nhưng việc giả mạo chứng chỉ hợp lệ là khó hơn).



8. Triển khai VPN, tường lửa

VPN thường tunnel toàn bộ traffic (bao gồm DNS) về máy chủ VPN, giảm nguy cơ bị tấn công DNS trên mạng công cộng; tuy nhiên với cấu hình split-tunnel hoặc DNS leak, DNS vẫn có thể bị rò rỉ. Tường lửa cũng là một công cụ mạnh mẽ để ngăn chặn các truy cập độc hại vào hệ thống.



9. Thường xuyên cập nhật phần mềm và firmware

Đối với các thiết bị mạng như router, modem, hãy luôn cập nhật firmware mới nhất. Các bản cập nhật này thường chứa các bản vá lỗi bảo mật, giúp bảo vệ thiết bị của bạn khỏi các cuộc tấn công **DNS Spoofing**.



10. Tăng cường giám sát hệ thống DNS

Đối với các quản trị viên hệ thống, việc giám sát lưu lượng DNS thường xuyên giúp phát hiện các hành vi bất thường, từ đó kịp thời ngăn chặn các cuộc tấn công **DNS Spoofing**.



* 1 số biện pháp phòng chống nâng cao :

11. Random hóa Transaction ID và Source Port

- **Mục đích:** làm tăng không gian đoán cho kẻ tấn công, giảm khả năng đoán trúng phản hồi giả và tiêm bản ghi vào cache.
- **Cách hoạt động (tóm tắt):** resolver/systems dùng ID truy vấn DNS (16-bit) kết hợp với cổng nguồn UDP (16-bit) — cả hai được random hóa độc lập để một phản hồi giả phải đoán cả hai mới được chấp nhận.

- **Lợi ích:** giảm mạnh khả năng thành công của cache poisoning bằng phương pháp đoán ID/cổng đơn giản.
- **Thực thi:** bật source-port randomization trên phần mềm resolver (BIND, Unbound, dnsmasq) và đảm bảo cập nhật phiên bản mới hỗ trợ cơ chế này.

12. DNS over HTTPS (DoH) vs DNS over TLS (DoT) — so sánh ngắn

- **Điểm chung:** cả hai đều mã hóa truy vấn DNS (bảo mật tính riêng tư, chống MITM trên đường truyền).
- **DoH (DNS over HTTPS):**
 - **Ưu:** dùng cổng HTTPS (443), dễ vượt tường lửa/captive portal; tích hợp tốt với trình duyệt; lợi thế về tương thích.
 - **Nhược:** có thể gây khó khăn cho quản trị nội bộ/giám sát (DNS visibility), dễ bị dùng để né chính sách mạng; phụ thuộc vào provider DoH.
- **DoT (DNS over TLS):**
 - **Ưu:** giao thức chuyên biệt cho DNS, dễ quản lý ở cấp mạng (port cố định 853), rõ ràng cho mục đích DNS-only.
 - **Nhược:** có thể bị chặn bởi thiết bị mạng hoặc firewall; triển khai trên client ít phổ biến hơn DoH.

Bảng so sánh DNS over HTTPS (DoH) và DNS over TLS (DoT)

Tiêu chí	DNS over HTTPS (DoH)	DNS over TLS (DoT)
Cổng sử dụng	443 (HTTPS)	853 (TLS chuyên biệt)
Mức độ triển khai	Phổ biến hơn, tích hợp sẵn trong trình duyệt (Chrome, Firefox...)	Ít phổ biến hơn, cần cấu hình client/server riêng
Ưu điểm	Dễ vượt tường lửa/captive portal; bảo mật cao; tương thích rộng	Chuyên biệt cho DNS; quản lý rõ ràng; dễ giám sát ở cấp mạng
Nhược điểm	Khó giám sát DNS nội bộ; có thể bị lợi dụng để né chính sách mạng	Có thể bị chặn bởi firewall; ít phổ biến hơn DoH
Khuyến nghị	Người dùng cá nhân nên bật DoH tới resolver uy tín	Doanh nghiệp/ISP nên triển khai DoT nội bộ để vừa mã hóa vừa giám sát

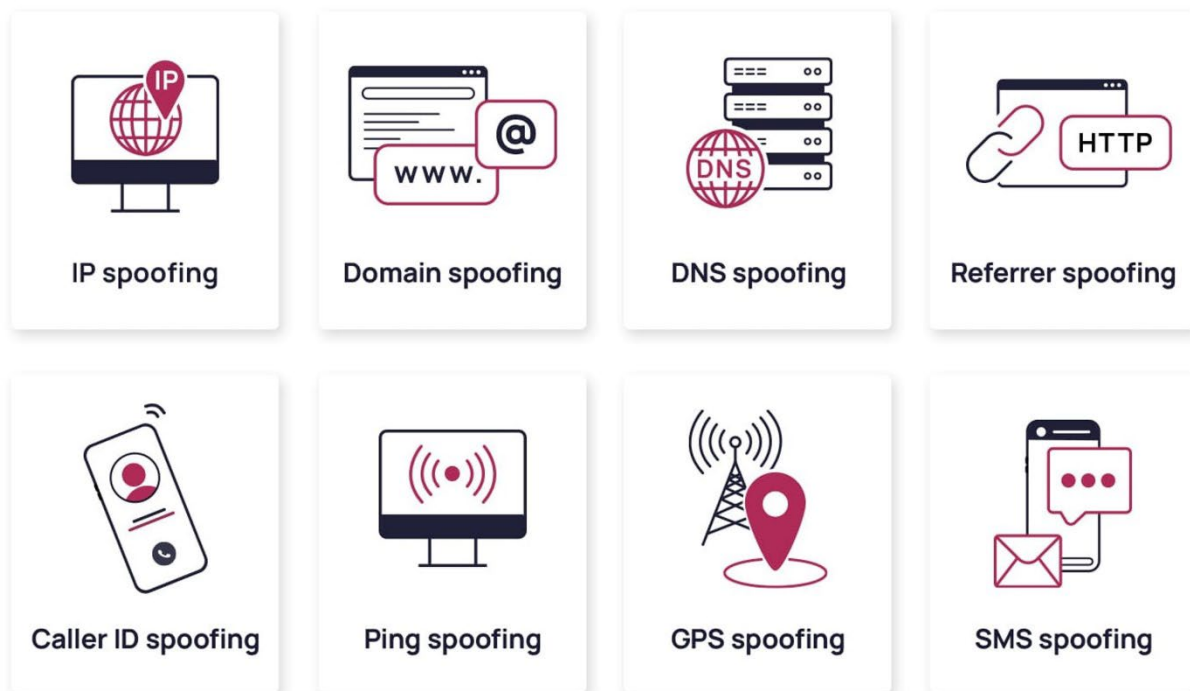
13. DNS Monitoring & Threat Intelligence

- **Mục tiêu:** phát hiện sớm các bất thường (cache poisoning, tunneling, spike NXDOMAIN, queries tới domain lạ) và phản ứng nhanh.
- **Thành phần chính:**
 - **Logging & Analytics:** lưu và phân tích query logs từ recursive resolvers (volume, pattern, entropy của subdomain).
 - **Alerting:** thiết lập ngưỡng cảnh báo (bùng nổ NXDOMAIN, tốc độ query cao, nhiều query tới domain không bình thường).
 - **Threat Intelligence Feeds:** so sánh domain/ IP với danh sách độc hại (blocklist, sinkhole) để phát hiện C2/exfiltration.
 - **Sandboxing & Forensics:** khi phát hiện nghi vấn, phân tích mẫu traffic, mẫu DNS payload để xác định vector (tunneling, malware).
- **Lợi ích:** giảm thời gian phát hiện (MTTD), tăng hiệu quả phản ứng (MTTR), giảm ảnh hưởng lan rộng khi resolver bị đầu độc.
- **Triển khai nhanh:** bật query logging (với privacy in mind), tích hợp SIEM/IDS, subscribe threat feeds, và định kỳ review logs.

IX. Các hình thức tấn công DNS Spoofing phổ biến ở Việt Nam

Sau khi đã tìm hiểu sơ qua về DNS Spoofing, giờ ta sẽ tìm hiểu các hình thức tấn công phổ biến ở Việt Nam, đi vào từng hình thức tấn công để có cái nhìn

khách quan giữa các hình thức.



1. Malware thay đổi DNS (client-side DNS hijack)

- **Tại sao phổ biến ở VN:** Nhiều người cài app/soft từ nguồn không rõ, dùng crack/APK bên ngoài; thói quen cấp quyền tùy tiện.
- **Cơ chế (ngắn):** Malware ghi đè file hosts, sửa DNS adapter/registry, hoặc đặt DNS của resolver thành DNS do attacker kiểm soát.
- **Dấu hiệu nhận biết:** Tất cả trang đều chuyển hướng; nhiều quảng cáo lạ; không đổi được DNS qua GUI.
- **Phòng chống:** Người dùng: cài AV/anti-malware, không cấp quyền admin tùy tiện, kiểm tra hosts; Tổ chức: endpoint protection, policy hạn chế cài phần mềm.

2. Router / modem compromise (DNS trên router bị đổi)

- **Tại sao phổ biến ở VN:** Router gia đình dùng mật khẩu mặc định hoặc firmware lâu không cập nhật.
- **Cơ chế (ngắn):** Kẻ tấn công chiếm quyền quản trị router (mật khẩu, UPnP, lỗ hổng) và thay DNS cho toàn mạng LAN.

- **Dấu hiệu nhận biết:** Tất cả thiết bị trong mạng bị redirect; DNS server trong router bị thay; truy cập web bất thường.
- **Phòng chống:** Đổi mật khẩu mặc định router, tắt quản trị từ xa, cập nhật firmware định kỳ, reset khi nghi ngờ.

3. Wi-Fi công cộng + MITM (Rogue AP / ARP spoofing)

- **Tại sao phổ biến ở VN:** Nhiều hotspot mở/miễn phí; người dùng hay kết nối mà không kiểm tra xác thực.
- **Cơ chế (ngắn):** Attacker tạo rogue AP hoặc dùng ARP spoofing để đứng giữa (MITM), chặn/redirect và thay DNS.
- **Dấu hiệu nhận biết:** Truy cập qua Wi-Fi công cộng bị chuyển hướng; cảnh báo chứng chỉ HTTPS/không hiển thị khóa.
- **Phòng chống:** Dùng VPN, ưu tiên DoH/DoT, tránh giao dịch nhạy cảm trên Wi-Fi công cộng, kiểm tra chứng chỉ HTTPS.

4. Phishing kết hợp DNS hijack (nhắm ngân hàng)

- **Tại sao phổ biến ở VN:** Mục tiêu giá trị (tài khoản ngân hàng), người dùng dễ tin trang tiếng Việt giả mạo.
- **Cơ chế (ngắn):** Kết hợp redirect DNS để dẫn user tới site giả mạo — thu credential/OTP hoặc lừa người dùng nhập mã.
- **Dấu hiệu nhận biết:** Trang login lạ, yêu cầu OTP bất thường, chứng chỉ TLS không khớp hoặc thiếu.
- **Phòng chống:** Kích hoạt 2FA, kiểm tra chứng chỉ TLS, đào tạo người dùng, giám sát domain và cảnh báo phishing.

5. DNS Cache Poisoning (nhắm resolver ISP/điểm trung gian)

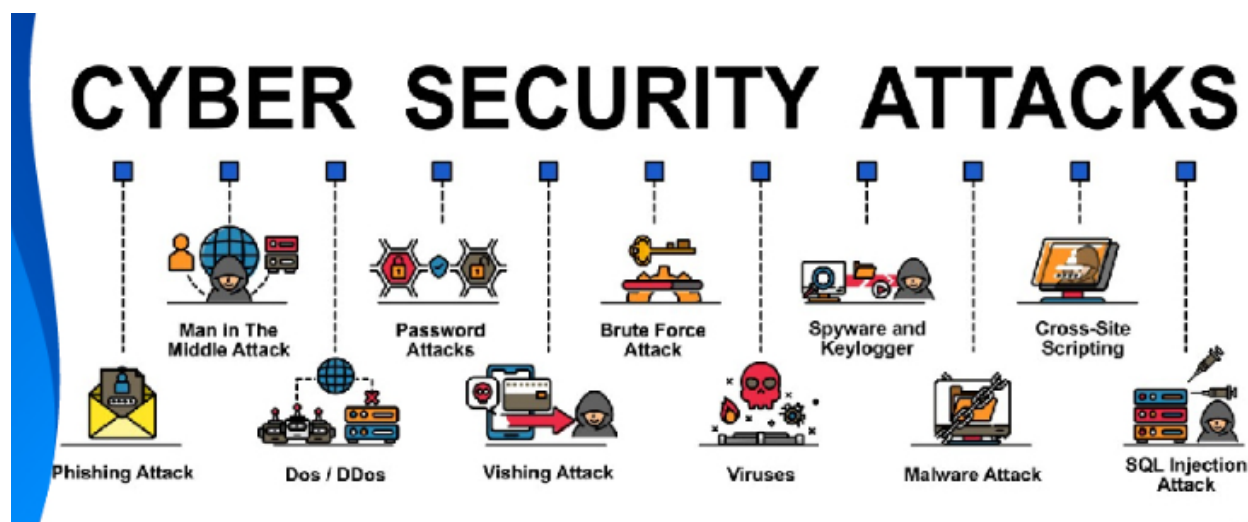
- **Tại sao phổ biến ở VN:** Một số resolver/ISP chưa triển khai DNSSEC hoặc cấu hình yếu; nhiều resolver nhìn chung dễ bị tấn công.
- **Cơ chế (ngắn):** Tiêm bản ghi giả vào cache resolver (poisoning) → ảnh hưởng hàng loạt user sử dụng resolver đó.
- **Dấu hiệu nhận biết:** Nhiều user cùng bị chuyển hướng tới cùng một IP lạ; truy vấn trả kết quả bất thường.
- **Phòng chống:** ISP/Tổ chức: triển khai DNSSEC, randomize source port/ID, cập nhật resolver, monitoring và filtering.

6. Rogue Public Resolver / DHCP cung cấp DNS độc hại

- **Tại sao phổ biến ở VN:** Người dùng tự đặt DNS hoặc các hotspot/DHCP cấp DNS độc hại; thiếu awareness khi chọn resolver.
- **Cơ chế (ngắn):** DHCP/hướng dẫn người dùng đặt resolver độc hại → trả kết quả giả, redirect traffic.
- **Dấu hiệu nhận biết:** DNS trả kết quả khác thường; queries tới resolver lạ; nhiều domain trả về IP kỳ lạ.
- **Phòng chống:** Dùng resolver uy tín (Cloudflare/Quad9/Google), cấu hình DoH/DoT, hardening DHCP (chỉ nhận DHCP từ nguồn tin cậy).

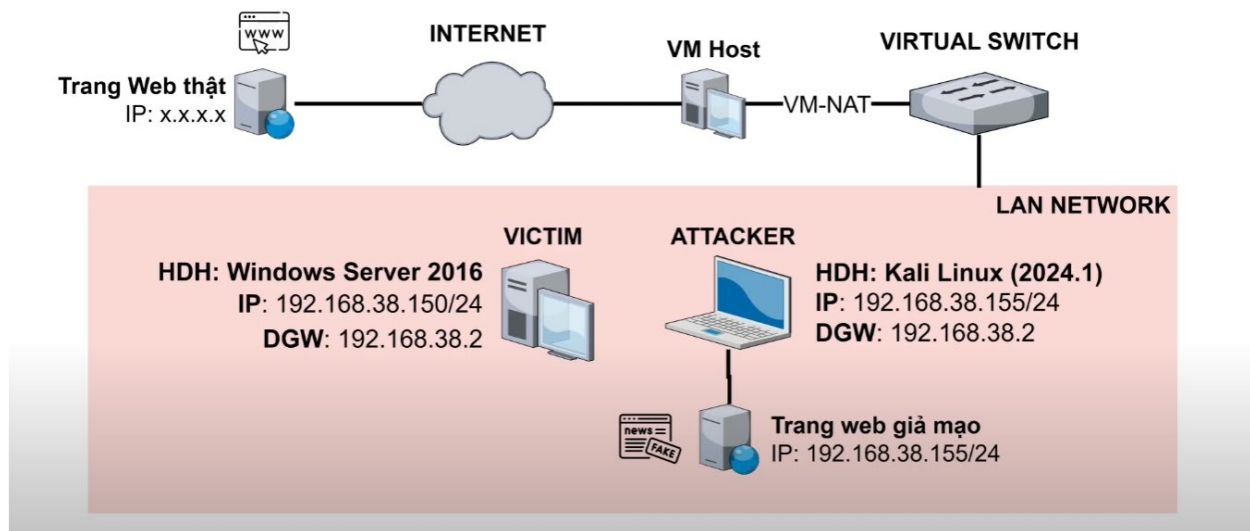
7. DNS Rebinding (nhắm IoT / dịch vụ nội bộ)

- **Tại sao phổ biến ở VN:** Nhiều IoT/thiết bị nội bộ có cấu hình yếu; dịch vụ nội bộ ít được bảo vệ kỹ.
- **Cơ chế (ngắn):** Trình duyệt được lừa truy vấn domain attacker → IP nội bộ (vòng lặp) → attacker tương tác với API nội bộ qua trình duyệt nạn nhân.
- **Dấu hiệu nhận biết:** Ứng dụng web nội bộ có request bất thường, hành vi API lạ, thiết bị nội bộ phản hồi cho domain bên ngoài.
- **Phòng chống:** Thiết kế app kiểm tra Origin/Host, CORS chặt, firewall nội bộ, cập nhật firmware IoT, tách mạng nội bộ và giới hạn truy cập từ web.



X. Demo hình thức tấn công DNS Spoofing.

MÔ HÌNH - DEMO HÌNH THỨC TẤN CÔNG DNS SPOOFING



1. Chuẩn bị các thiết bị

- Máy VM-WinS2016(victim)
- + Thiết lập IP tĩnh : 192.168.38.150/24
- + Cài đặt XARP
- Máy VM-KALI (Attacker)
- + Thiết lập IP tĩnh : 192.168.38.155/24
- Kết quả : VM ra được Internet và ping nhau

2. Thiết lập ETTERCAP trên KALI LINUX

2.1. Host web giả mạo trên python

- Tạo một lệnh site giả mạo đơn giản
- Dùng lệnh : `python -m http.server 80`
- Truy cập thử site giả mạo

2.2. Thiết lập Ettercap (etter.dns)

- Đường dẫn: /etc/ettercap/etter.dns
 - Thêm nội dung
- | | | |
|-----------------|-----|----------------|
| dantri.com.vn | A | 192.168.38.155 |
| *.dantri.com.vn | A | 192.168.38.155 |
| dantri.com.vn | PTR | 192.168.38.155 |

2.3. Tổ chức tấn công

- Khởi chạy Web Server bằng Python
- Kiểm tra file etter.dns
- Bật chương trình Ettercap (nhập pass: kali)
- Trên chương trình Ettercap
- + Quét Host và thêm Target 1
- + Target 1 là WinS và Target 2 là ALL
- + Chọn Plugins: dns_spoofing (script)
- + Xem thông báo hiển thị tấn công

3. Kiểm tra kết quả

- Phần mềm XARP phát cảnh báo tấn công
- Bảng ARP Cache bị thay đổi (arp -a)
- + MAC Address bị trùng lặp trên IP
- + So sánh với bảng ARP Cache trước đó
- Ping lại trang cho kết quả là IP của Kali
- + IP trở về máy Kali
- + Truy cập lại sẽ vào trang web giả mạo

XI. Kết luận

DNS Spoofing là một mối đe dọa thực sự, có thể gây ra những hậu quả nghiêm trọng. Tuy nhiên, bằng cách hiểu rõ bản chất của cuộc tấn công và áp dụng các biện pháp phòng chống hiệu quả, bạn hoàn toàn có thể bảo vệ bản thân và hệ thống của mình.

Hy vọng với những thông tin mà chúng mình cung cấp, mọi người sẽ có cái nhìn toàn diện hơn về **DNS Spoofing** và biết cách giữ an toàn khi lướt web. Hãy luôn cảnh giác và đừng bao giờ xem nhẹ vấn đề bảo mật.